

AUDITORIA

Ruben Antonio Muñoz Bustos
Sergi Terrones Gallardo

AUTH SERVICE

FALLO 1:

Línea y fichero en el que está ubicado el error:	Líneas: 66–72 (CalcularHash) Fichero: AuthService.cs
Según los apuntes, ¿qué antipatrón es?	Uso de hash simple sin sal (Salt) y uso de un algoritmo rápido en lugar de un algoritmo lento de contraseñas. (Según los apuntes, las contraseñas deben guardarse siempre como hash con sal usando algoritmos lentos específicos para contraseñas como PBKDF2, bcrypt o Argon2).
Si fueras un atacante, ¿cómo lo utilizarías?	Al no utilizar sal (salt), contraseñas idénticas producen exactamente el mismo hash MD5. Si obtengo el contenido de la base de datos, utilizaría tablas arcoíris (rainbow tables) o ataques de fuerza bruta masiva acelerados por GPU
Indica el nivel de gravedad: alto, medio, bajo	Alta, porque si alguien obtiene la base de datos, descifra todas las contraseñas a la vez.

FALLO 2:

Línea y fichero en el que está ubicado el error:	Fichero: AuthService.cs Líneas: 74–79 (GuardarSesionEnDisco)
Según los apuntes, ¿qué antipatrón es?	Guardar los datos de sesión en un fichero de texto plano, sin cifrar ni firmar. Según los apuntes, la app cliente no es de fiar, los ficheros de texto los puede editar cualquiera, y la fuente de verdad debería ser el servidor.
Si fueras un atacante, ¿cómo lo utilizarías?	Abriría el fichero local sesion.txt y modificaría el nombre escrito por el de otro usuario (ej. "admin"). Si el cliente de la aplicación confía en la lectura de este fichero sin validar ni verificar su integridad en el servidor ni mediante HMAC, lograría suplantar la identidad de otro jugador.
Indica el nivel de gravedad: alto, medio, bajo	Medio, porque requiere acceso al dispositivo, pero permite suplantar sesiones.

FALLO 3

Línea y fichero en el que está ubicado el error:	Fichero: AuthService.cs Línea: 50 (if (usuario.ContrasenaHash != hashIntento))
Según los apuntes, ¿qué antipatrón es?	Comparación no segura de cadenas en operaciones criptográficas (Ataque de tiempo / Timing Attack).
Si fueras un atacante, ¿cómo lo utilizarías?	La comparación de cadenas con el operador != finaliza la comprobación en el primer carácter que no coincide. Midiendo con alta precisión los microsegundos de respuesta del servidor en múltiples intentos, podría ir adivinando el hash carácter a carácter por diferencias de tiempo de ejecución.
Indica el nivel de gravedad: alto, medio, bajo	Bajo / Medio, porque es difícil de explotar, pero es una mala práctica.

FALLO 4:

Línea y fichero en el que está ubicado el error:	Fichero: AuthService.cs Líneas: 21 y 26 (throw new ArgumentException(...))
Según los apuntes, ¿que antipatrón es?	Manejo explícito de errores mediante excepciones no capturadas que exponen detalles técnicos de validación. (Según los apuntes, al usuario debe mostrarse un mensaje genérico y no exponer detalles ni dar pistas innecesarias).
Si fueras un atacante, ¿cómo lo utilizarías?	Provocaría errores intencionados enviando entradas malformadas para analizar los mensajes devueltos por las excepciones y deducir la estructura exacta de las reglas de validación internas.
Indica el nivel de gravedad: alto, medio, bajo	Bajo,, porque da pistas al atacante, aunque no es crítico.

RED SERVICE

FALLO 1:

Línea y fichero en el que está ubicado el error:	Fichero: RedService.cs Línea: 8
Según los apuntes, ¿qué antipatrón es?	Clave o secreta escrita en el código (Hardcoded Secrets / Hardcoded API Key).
Si fueras un atacante, ¿cómo lo utilizarías?	Descompilaría el ejecutable con ILSpy o dnSpy y sacaría la ApiKey privada en segundos. Con ella podría hacer peticiones a la API como si fuera la app, gastar recursos o modificar datos.
Indica el nivel de gravedad: alto, medio, bajo	Alto, porque se extrae fácilmente al descompilar la app.

FALLO 2

Línea y fichero en el que está ubicado el error:	Fichero: RedService.cs Línea: 9
Según los apuntes, ¿que antipatrón es?	Comunicación sin cifrar a través de HTTP (Uso de HTTP en lugar de HTTPS).
Si fueras un atacante, ¿cómo lo utilizarías?	Interceptaría el tráfico de red mediante un ataque Man-in-the-Middle (MitM) con herramientas como Wireshark o Fiddler. Al no usar TLS/HTTPS, podría leer todo el contenido transmitido (parámetros, datos, claves) e incluso modificar al vuelo la información enviada al servidor.
Indica el nivel de gravedad: alto, medio, bajo	Alto, porque todo el tráfico va sin cifrar y se puede leer o modificar.

FALLO 3

Línea y fichero en el que está ubicado el error:	Fichero: RedService.cs Línea: 25
Según los apuntes, ¿qué antipatrón es?	Paso de credenciales y datos en la URL / GET inseguro para operaciones con efectos de lado.
Si fueras un atacante, ¿cómo lo utilizarías?	Los parámetros pasados por URL en una petición GET quedan expuestos en los registros (logs) de servidores proxy, en el historial del navegador/sistema y en la red. Obtendría la api_key y manipularía los parámetros usuario y puntos directamente en la URL enviada para falsear las puntuaciones.
Indica el nivel de gravedad: alto, medio, bajo	Medio, porque la URL queda expuesta en logs e historiales.

FALLO 4:

Línea y fichero en el que está ubicado el error:	Fichero: RedService.cs Línea: 27
Según los apuntes, ¿que antipatrón es?	Registro / logging de información sensible (Exposición de credenciales en logs).
Si fueras un atacante, ¿cómo lo utilizarías?	Inspeccionaría la salida por consola o los registros de la aplicación en el dispositivo local para leer la URL completa y extraer la api_key sin necesidad de interceptar el tráfico ni descompilar la app.
Indica el nivel de gravedad: alto, medio, bajo	Medio, porque cualquiera con acceso al log obtiene la API Key.

FALLO 5:

Línea y fichero en el que está ubicado el error:	Fichero: RedService.cs Línea: 21 (EnviarPuntuacionAsync)
Según los apuntes, ¿qué antipatrón es?	Falta de validación de los datos de entrada antes de enviarlos.
Si fueras un atacante, ¿cómo lo utilizarías?	Injectaría un nombreUsuario con caracteres especiales de formato URL (por ejemplo &puntos=99999) o cadenas vacías para romper el formato de la consulta o falsear los datos registrados en el servidor.
Indica el nivel de gravedad: alto, medio, bajo	Medio, porque permite falsear datos o romper el formato de la petición.

BaseDatosUsuarios.cs

FALLO 1:

Línea y fichero en el que está ubicado el error:	BaseDatosUsuarios.cs, en el método BuscarPorNombre. La línea concreta es:30
Según los apuntes, ¿que antipatrón es?	Concatenar datos que vienen del usuario dentro de una consulta SQL. Según los apuntes es una inyección SQL, ello va en contra de las buenas practicas
Si fueras un atacante, ¿cómo lo utilizarías?	En el campo de usuario del login escribiría algo como ' OR '1'='1. Como ese texto se coloca como consulta, la condición siempre será verdadera y me devuelve el primer usuario de la base de datos. Si el código no comprueba la contraseña después, podría entrar directamente sin saberla.
Indica el nivel de gravedad: alto, medio, bajo	Alta, porque permite saltarse el login y acceder a cuentas de otros usuarios. En una base de datos real incluso se podrían borrar tablas

FALLO 2:

Línea y fichero en el que está ubicado el error:	BaseDatosUsuarios.cs, métodos BuscarExacto y BuscarPorNombre. La línea concreta empieza desde el 25 al 34
Según los apuntes, ¿qué antipatrón es?	Falta de validación de entrada. Va contra el punto 1 de los apuntes sobre la Validación de los datos de entrada y también contra el principio de no confiar en la entrada
Si fueras un atacante, ¿cómo lo utilizarías?	Enviaría nombres vacíos, larguísimos o con caracteres especiales que podrían provocar errores o hasta lograr colapsar la app
Indica el nivel de gravedad: alto, medio, bajo	No llega a ser crítica por sí sola, pero al no comprobar lo que entra, deja la puerta abierta a ataques más serios como la inyección SQL.

FALLO 3:

Línea y fichero en el que está ubicado el error:	BaseDatosUsuarios.cs, método EjecutarConsultaSimulada. La línea es: 43
Según los apuntes, ¿qué antipatrón es?	Es una puerta trasera (backdoor) porque el propio código simula y deja activo el ataque de inyección SQL. Va contra los principios de no confiar en la entrada y la de Fallar de forma segura que se indica en los apuntes.
Si fueras un atacante, ¿cómo lo utilizarías?	Podría escribir ' OR '1'='1 en cualquier campo de texto que llegue hasta ahí, y me devolvería el primer usuario. Es como si el código se dejara atrapar por el ataque.
Indica el nivel de gravedad: alto, medio, bajo	Alta, porque garantiza el acceso no autorizado y es la materialización directa del fallo de inyección SQL. Con esto solo, ya entras al sistema.

program.cs

FALLO 1:

Línea y fichero en el que está ubicado el error:	Program.cs, método CargarUsuariosDeEjemplo, y línea: 19
Según los apuntes, ¿qué antipatrón es?	Clave o contraseña escrita en el código
Si fueras un atacante, ¿cómo lo utilizarías?	Puede abrir el código o descompilarlo y ver las credenciales directamente. Lo cual lo puede utilizar para iniciar sesión como admin
Indica el nivel de gravedad: alto, medio, bajo	Alta, porque las credenciales del admin están expuestas.

FALLO 2:

Línea y fichero en el que está ubicado el error:	Program.cs, bloque catch dentro de Main, línea:
Según los apuntes, ¿que antipatrón es?	Mostrar el error completo al usuario
Si fueras un atacante, ¿cómo lo utilizarías?	Puedo leer los errores y darme pistas sobre el funcionamiento
Indica el nivel de gravedad: alto, medio, bajo	Media, porque da información al atacante.

FALLO 3:

Línea y fichero en el que está ubicado el error:	Program.cs, método VerPerfil, línea:145
Según los apuntes, ¿que antipatrón es?	Registro/muestra de datos sensibles
Si fueras un atacante, ¿cómo lo utilizarías?	Si puedo ver el token, puedo suplantar la sesión del usuario
Indica el nivel de gravedad: alto, medio, bajo	Media, porque expone un dato sensible.

FALLO 4:

Línea y fichero en el que está ubicado el error:	Program.cs, método PanelAdministracion: empieza en la línea 148
Según los apuntes, ¿que antipatrón es?	Control de acceso solo en el cliente. El punto 7 dice que los permisos se comprueban en el servidor y que ocultar un botón no protege nada.
Si fueras un atacante, ¿cómo lo utilizarías?	Me fijo en que el menú tiene una opción 5 que no me sale porque no soy admin. Pero como sé que existe por que lo puedo ver en el código, al ingresar el 5 puedo ingresar como admin sin ser el administrador
Indica el nivel de gravedad: alto, medio, bajo	Media, por que permite saltarse el control de roles y entrar como administrador y ver la lista de usuarios

FALLO 5:

Línea y fichero en el que está ubicado el error:	Program.cs, métodos Registrar e IniciarSesion, línea 99 y 111
Según los apuntes, ¿que antipatrón es?	Este caso no está recogido explícitamente en los apuntes. Se puede relacionar con el punto 8 de que nunca registres contraseñas, tokens o datos personales, aunque esa frase habla de logs, pero de igual manera se considera malo que las contraseñas se puedan visualizar en la pantalla sin estar ocultos
Si fueras un atacante, ¿cómo lo utilizarías?	Podría mirar la pantalla del usuario mientras escribe su contraseña y también quedaría visible en capturas de pantalla o grabaciones.
Indica el nivel de gravedad: alto, medio, bajo	Medio, porque requiere que se pueda ver la pantalla para poder acceder a la información de la contraseña.